BEZPIECZEŃSTWO APLIKACJI INTERNETOWYCH

LAB / PROJ • edycja 2026

Projekt praktyczny: zaprojektuj • przetestuj • napraw • obroń

dr inż. Jarosław Homa, MBA, CISO

Akademia WSB • 04.10.2026

PUNKT WYJŚCIA

Od dobrego projektu do nowoczesnego bezpieczeństwa aplikacji (AppSec)

ZOSTAJE

- projekt zespołowy 2–3 osoby
- część praktyczna + analityczna
- raport, demo i repozytorium
- analiza ryzyka i remediacja
- testowanie wyłącznie w kontrolowanym środowisku

AKTUALIZUJEMY

- OWASP Top 10:2021 → 2025
- ASVS → 5.0.0
- WebAuthn / passkeys
- bezpieczeństwo API i multi-tenant
- SBOM / supply chain / DevSecOps
- „fail secure” i observability

UPRASZCZAMY

- jeden jasny Definition of Done
- raport 8–12 stron + dowody w repo
- preferowane zaliczenie 25.10
- 21.11 tylko jako termin końcowy
- zaliczenie od razu po akceptacji projektu

Źródło bazowe: materiały prowadzącego z poprzednich edycji przedmiotu.

Prowadzący



dr inż. Jarosław Homa, MBA, CISO

Cyberbezpieczeństwo • architektura • audyt • zarządzanie • dydaktyka

- Pełnomocnik Rektora ds. Cyberbezpieczeństwa / CISO Politechniki Śląskiej; zastępca Dyrektora Centrum Cyberbezpieczeństwa
- Audytor wiodący ISO/IEC 27001 i ISO 22301; MBA – Zarządzanie Cyberbezpieczeństwem
- Wieloletni wykładowca i praktyk: bezpieczeństwo systemów, sieci, audyt IT, zarządzanie projektami
- Kierownik Akademii Cisco; ekspert NCBR; członek m.in. ISACA i PTI

Na tym przedmiocie interesuje mnie nie „ładny opis”, ale dowód, że potraficie zbudować, złamać we własnym labie, poprawić i zweryfikować rozwiązanie.

Akademia WSB

PO CO TEN PROJEKT

Cel przedmiotu

Po zaliczeniu student powinien umieć przejść pełny cykl bezpieczeństwa aplikacji (AppSec) – od modelu zagrożeń do dowodu skuteczności poprawki.

1

ZROZUMIEĆ

architekturę, zasoby, powierzchnię ataku

2

ZNALEŹĆ

podatność lub ryzyko i zebrać dowody

3

OCENIĆ

wpływ, ryzyko i mapowanie do standardu

4

NAPRAWIĆ

kod, konfigurację, proces albo architekturę

5

ZWERYFIKOWAĆ

test ponowny (retest): poprawka działa i nie psuje systemu

Klucz: projekt ma kończyć się zmianą stanu bezpieczeństwa – nie samą listą podatności.

ORGANIZACJA

Model zajęć w liczbach

26 studentów
grupa GL01

9 zespołów
8 × 3 osoby + 1 × 2 osoby

4 spotkania
04.10 • 18.10 • 25.10 • 21.11

1 projekt
zaakceptowany = zaliczenie

Założenie prowadzenia

Im szybciej zespół pokaże kompletny, działający i udokumentowany projekt, tym szybciej kończy przedmiot.

Nie czekamy „dla zasady” do ostatniego terminu.

STANDARDY I METODYKI

Punkt odniesienia 2026: na czym pracujemy

OWASP Top 10

2025
10 głównych kategorii ryzyka aplikacji

OWASP ASVS

5.0.0
standard weryfikacji zabezpieczeń aplikacji

OWASP WSTG

4.2
przewodnik testów bezpieczeństwa aplikacji webowych

OWASP API Top 10

2023
10 głównych ryzyk interfejsów API

NIST SSDF

SP 800-218 v1.1
ramy bezpiecznego wytwarzania oprogramowania

CWE / CVSS / STRIDE

uzupełniająco
słabości • ocena ryzyka • modelowanie zagrożeń

Reguła projektu: wykorzystaj minimum 2 uznane odniesienia – jedno do „co zabezpieczyć”, drugie do „jak zweryfikować”.

Stan źródeł: 03.10.2026 • OWASP / NIST (oficjalne projekty i publikacje).

OWASP, NIST i W3C — kto jest kim?

OWASP

Open Worldwide Application Security Project

Międzynarodowa społeczność tworząca bezpłatne materiały o bezpieczeństwie aplikacji.

W przedmiocie: Top 10, ASVS, WSTG i API Security Top 10.

NIST (USA)

National Institute of Standards and Technology
Narodowy Instytut Standaryzacji i Technologii USA.

Publikuje standardy i wytyczne. NIST SSDF z publikacji SP 800-218 opisuje bezpieczne wytwarzanie oprogramowania.

Uwaga: to nie polski NIST – Narodowy Instytut Samorządu Terytorialnego.

W3C

World Wide Web Consortium
Konsorcjum standaryzujące technologie WWW.

W przedmiocie: WebAuthn – standard silnego uwierzytelniania kluczami kryptograficznymi, wykorzystywany m.in. przez klucze dostępu (passkeys).

Jak czytać „NIST SP 800-218 – SSDF v1.1”: NIST = autor → SP 800-218 = numer publikacji → SSDF = nazwa ram → v1.1 = wersja.

TERMINOLOGIA

Skróty i pojęcia — szybka ściąga

TOŻSAMOŚĆ I DOSTĘP

MFA – uwierzytelnianie wieloskładnikowe
TOTP – jednorazowy kod zależny od czasu
RBAC – kontrola dostępu oparta na rolach
ABAC – kontrola dostępu oparta na atrybutach
BOLA/IDOR – błędy autoryzacji dostępu do obiektów

TESTOWANIE

SAST – statyczna analiza bezpieczeństwa kodu
DAST – dynamiczne testy działającej aplikacji
SCA – analiza bibliotek i zależności
Code review – przegląd kodu
Retest – test ponowny po poprawce

WEB / API

XSS – wstrzyknięcie skryptu do strony
CSRF – wymuszenie żądania w imieniu użytkownika
CSP – polityka bezpieczeństwa treści
SSRF – żądanie wykonane przez serwer do wskazanego zasobu
Rate limiting – ograniczanie liczby żądań

PROCES I ŁAŃCUCH DOSTAW

CI/CD – ciągła integracja i dostarczanie
SBOM – wykaz składników oprogramowania
CVE – identyfikator znanej podatności
CWE – klasyfikacja typów słabości
CVSS – skala oceny dotkliwości podatności

AKTUALIZACJA 2026

OWASP Top 10:2025 — mapa ryzyk

A01	Nieprawidłowa kontrola dostępu (Broken Access Control)
A02	Błędna konfiguracja bezpieczeństwa (Security Misconfiguration)
A03	Błędy łańcucha dostaw oprogramowania (Software Supply Chain Failures)
A04	Błędy kryptograficzne (Cryptographic Failures)
A05	Wstrzykiwanie danych lub kodu (Injection)
A06	Niebezpieczny projekt (Insecure Design)
A07	Błędy uwierzytelniania (Authentication Failures)
A08	Błędy integralności oprogramowania lub danych (Integrity Failures)
A09	Błędy rejestrowania i alarmowania bezpieczeństwa (Logging & Alerting Failures)
A10	Nieprawidłowa obsługa sytuacji wyjątkowych (Exceptional Conditions)

OWASP Top 10:2025 — aktualnie wydana wersja OWASP Top 10.

CO MUSICIE UMIEĆ

Program merytoryczny: 8 bloków bezpieczeństwa aplikacji (AppSec)

01 Modelowanie zagrożeń (Threat modeling)

zasoby • DFD – diagram przepływu danych • STRIDE • wymagania bezpieczeństwa

02 Tożsamość i dostęp

klucze dostępu (passkeys) / MFA • sesje • RBAC/ABAC • BOLA/IDOR

03 Przeglądarka i dane

XSS • CSRF • CSP – polityka bezpieczeństwa treści • walidacja • przesyłanie plików

04 Interfejsy API

REST/GraphQL • schemat danych • autoryzacja • ograniczanie liczby żądań (rate limiting)

05 Integracje

SSRF – fałszowanie żądań po stronie serwera • usługi zewnętrzne • granice zaufania

06 Łańcuch dostaw oprogramowania (Supply chain)

zależności • CVE – znane podatności • SBOM – wykaz składników • integralność artefaktów kompilacji

07 DevSecOps – bezpieczeństwo w procesie DevOps

SAST – analiza statyczna • SCA – zależności • sekrety • DAST – testy dynamiczne • bramki jakości

08 Monitoring i odporność (Observability & resilience)

logi • alerty • bezpieczne zachowanie przy awarii (fail secure) • obsługa wyjątków

PRZEBIEG PRACY

Jak pracujemy: jedna ścieżka dla każdego projektu

1 Zakres (Scope)

co badamy / czego nie badamy

2 Model

zasoby • zagrożenia • hipotezy

3 Testy

ręczne / automatyczne / przegląd kodu (code review)

4 Dowody (Evidence)

żądania HTTP • logi • zrzuty ekranu • testy

5 Działania naprawcze (Remediation)

kod / konfiguracja / architektura

6 Test ponowny (Retest)

dowód, że poprawka działa

7 Raport (Report)

mapowanie • ryzyko • wnioski

8 Demonstracja (Demo)

obrona rozwiązania

Nie uznaję projektu, w którym nie ma etapu 5–6: działania naprawcze + test ponowny (retest).

ORGANIZACJA PRACY

Zespół projektowy: 2–3 osoby

Przy 26 osobach rekomendowany układ to 9 zespołów: 8 trzyosobowych i 1 dwuosobowy.

BEZPIECZEŃSTWO / TESTY

model zagrożeń • scenariusze • testy • dowody

IMPLEMENTACJA / NAPRAWA

implementacja • utwardzanie (hardening) • poprawki • test ponowny

RAPORT / ODTWARZALNOŚĆ

repozytorium • odtwarzalność • mapowanie • dokumentacja

Role pomagają podzielić pracę, ale na obronie każdy członek zespołu powinien rozumieć cały projekt.
W karcie projektu wpisujemy indywidualny wkład.

TERMINY

Harmonogram — cel: zamknąć projekt 25 października

04.10

START PROJEKTU (KICK-OFF)

1

zespół + temat + zakres

dziś

18.10

PRZEGLĄD KONTROLNY (CHECKPOINT)

2

środowisko + model + pierwsze dowody

ok. 40%

25.10

PREFEROWANE ZALICZENIE

3

demonstracja + raport + repozytorium + test ponowny

zaakceptowany = koniec

21.11

TERMIN KOŃCOWY

4

tylko projekty niezaakceptowane / poprawki

termin nieprzekraczalny

Proponowany mikrotermin: Karta projektu v0.1 do 11.10 (1 strona) — żeby 18.10 pracować już na konkretach.

PAKIET ZALICZENIOWY

Co dokładnie oddaje zespół

01 9B005D

1 strona: zakres, hipoteza, standardy, role, kryteria ukończenia (DoD)

02 2563EB

kod lub konfiguracja + instrukcja uruchomienia + dane testowe

03 0891B2

8–12 stron + dowody / załączniki w repozytorium

04 16A34A

10–12 min + 3 min pytań; obowiązkowy test ponowny (retest)

Minimalny zestaw dowodów: architektura / DFD (diagram przepływu danych) • scenariusze testowe • wynik „przed” • poprawka • wynik „po” • mapowanie do standardów.

AKCEPTACJA

Kryteria ukończenia (Definition of Done) — bramki zaliczenia

✓	**01 LEGALNY ZAKRES**	testy tylko w laboratorium / własnym środowisku	✓	**02 DZIAŁA**	środowisko można uruchomić i odtworzyć
✓	**03 JEST DOWÓD**	podatność / ryzyko pokazane technicznie	✓	**04 JEST POPRAWKA**	działanie naprawcze wdrożone albo wiarygodnie zaprojektowane
✓	**05 JEST TEST PONOWNY**	zespół pokazuje zmianę wyniku po poprawce	✓	**06 JEST MAPOWANIE**	min. 2 źródła/metodyki + ryzyko
✓	**07 JEST ODTWARZALNOŚĆ**	repozytorium i raport pozwalają odtworzyć pracę	✓	**08 JEST OBRONA**	każdy członek rozumie projekt

Wszystkie bramki spełnione → PROJEKT ZAAKCEPTOWANY → przedmiot zaliczony.

100 PUNKTÓW

Matryca oceny — punktacja jako feedback



Ważne: punkty nie zastępują bramek kryteriów ukończenia (Definition of Done). Krytyczny brak (np. brak testu ponownego albo praca na nieautoryzowanym celu) = brak akceptacji niezależnie od sumy punktów.

12 ORYGINALNYCH PROPOZYCJI

Tematy projektów — zestaw A

P1 Klucze dostępu 2026 (Passkeys)

WebAuthn / klucze dostępu kontra TOTP – jednorazowe kody czasowe

Zbuduj moduł logowania i sprawdź bezpieczne ścieżki rejestracji, logowania, odzyskiwania dostępu (recovery) i ścieżki awaryjnej (fallback).

ASVS 5 • WebAuthn L3 • A07

P2 Autoryzacja w aplikacji wielodostępnej (Multi-tenant)

BOLA/IDOR – błędy dostępu do obiektów • RBAC/ABAC – kontrola oparta na rolach/atrybutach

Mini-usługa dla wielu klientów (SaaS): znajdź eskalacje uprawnień, zaprojektuj macierz dostępu i testy negatywne.

A01 • API Top 10 • ASVS

P3 Ochrona interfejsu API (API Shield)

REST / GraphQL • utwardzanie zabezpieczeń (hardening)

Autoryzacja obiektów, walidacja schematu, ograniczanie liczby żądań (rate limiting), ochrona przed masowym przypisaniem danych (mass assignment), minimalizacja błędów i danych.

API Top 10 2023 • ASVS

P4 SBOM i kontrola łańcucha dostaw

CycloneDX • SCA – analiza składników • CVE – znane podatności

Wygeneruj SBOM (wykaz składników oprogramowania), wykryj ryzyka zależności i zbuduj bramkę blokującą nieakceptowalne ryzyko.

A03 • NIST SSDF • CWE/CVSS

12 ORYGINALNYCH PROPOZYCJI

Tematy projektów — zestaw B

P5 Potok bezpieczeństwa DevSecOps

SAST – analiza statyczna • SCA – zależności • sekrety • DAST – testy dynamiczne

Zbuduj potok CI/CD (ciągła integracja i dostarczanie), który automatycznie wykrywa problemy, generuje dowody i egzekwuje politykę jakości.

SSDF • ASVS • Top 10

P6 Bezpieczne przesyłanie plików (Secure Upload)

pliki • MIME • ZIP/SVG • przejście ścieżek (path traversal)

Pokaż ryzyka przesyłania plików w laboratorium, a następnie wdroż kwarantannę, bezpieczne nazwy i kontrolę dostępu.

ASVS • WSTG • Top 10

P7 Utwardzanie przeglądarki 2026 (Browser Hardening)

DOM XSS • CSP – polityka bezpieczeństwa treści • CSRF • nagłówki HTTP

Zbuduj podatną warstwę przeglądarkową (frontend), pokaż demonstrację ataku (exploit) w laboratorium, następnie wdroż zabezpieczenia i wykonaj test ponowny.

A02/A05 • ASVS • WSTG

P8 SSRF i granica zaufania chmury

symulacja metadanych • lista dozwolonych adresów (allowlist) • ruch wychodzący (egress)

Zasymuluj niebezpieczne pobieranie adresów URL i obroń system przed przekierowaniami (redirect), nadużyciami DNS oraz różnicami interpretacji adresu przez parser.

WSTG • ASVS • Top 10

12 ORYGINALNYCH PROPOZYCJI

Tematy projektów — zestaw C

P9 Monitoring i obserwowalność bezpieczeństwa

logi • korelacja • alerty • panel monitoringu (dashboard)

Zaprojektuj zdarzenia bezpieczeństwa i panel monitoringu dla logowania, zmian uprawnień i odrzuconych żądań.

A09 • ASVS

P10 Bezpieczne zachowanie przy awarii (Fail Secure) / A10:2025

wyjątki • limity czasu (timeouts) • limity zasobów

Pokaż, jak system zachowuje się przy błędach częściowych, przeciążeniu i wyjątkach – bez wycieku informacji i bez niekontrolowanego otwarcia dostępu (fail-open).

A10:2025 • ASVS

P11 Bezpieczeństwo komunikacji WebSocket

Origin – pochodzenie • autoryzacja • ponowne odtworzenie (replay) • limit żądań

Mini-czat lub strumień zdarzeń: zabezpiecz zestawianie połączenia (handshake) i wiadomości, przetestuj ponowne odtworzenie komunikatów oraz nadużycia.

ASVS • WSTG

P12 Bezpieczne programowanie wspomagane AI

kod generowany przez AI oceniany z perspektywy bezpieczeństwa aplikacji (AppSec)

Wygeneruj wybraną funkcję webową z pomocą AI, zweryfikuj ją według ASVS/WSTG, napraw i porównaj stan przed i po poprawce (before/after).

Top 10 • ASVS • WSTG

P1 wykorzystuje aktualny standard WebAuthn Level 3 (W3C Recommendation, 25.08.2026).

Matryca tematów i kompetencji

Projekt	AUTH ACCESS	API	BROWSER INPUT	SUPPLY DEVSECOPS	MONITORING	RESILIENCE
P1 Klucze dostępu 2026 (Passkeys)	•		•			
P2 Autoryzacja w aplikacji wielodostępnej (Multi-tenant)	•	•				
P3 Ochrona interfejsu API (API Shield)	•	•	•			•
P4 SBOM i kontrola łańcucha dostaw				•		
P5 Potok bezpieczeństwa DevSecOps		•	•	•	•	
P6 Bezpieczne przesyłanie plików (Secure Upload)	•		•			
P7 Utwardzanie przeglądarki 2026 (Browser Hardening)	•		•			
P8 SSRF i granica zaufania chmury		•			•	•
P9 Monitoring i obserwowalność bezpieczeństwa	•	•			•	
P10 Bezpieczne zachowanie przy awarii (Fail Secure) / A10:2025		•			•	•
P11 Bezpieczeństwo komunikacji WebSocket	•	•	•		•	•
P12 Bezpieczne programowanie wspomagane AI	•	•	•	•		

• = kompetencja dominująca w projekcie. Każdy projekt dodatkowo rozwija analizę ryzyka, dokumentowanie i remediację.

SZABLON

Karta projektu v0.1 — jedna strona, która porządkuje pracę

1	**ZESPÓŁ**	skład + role + kontakt
2	**TEMAT I CEL**	co ma się zmienić w bezpieczeństwie
3	**ZAKRES (SCOPE)**	w zakresie / poza zakresem / granice testów
4	**ŚRODOWISKO**	technologie + architektura + uruchomienie
5	**HIPOTEZA / TESTY**	co sprawdzamy i jak pokażemy dowód
6	**STANDARDY**	min. 2: np. ASVS + WSTG/API Top 10
7	**KRYTERIA UKOŃCZENIA (DoD)**	jak poznamy, że projekt jest zakończony
8	**KAMIENIE MILOWE**	18.10 przegląd • 25.10 termin preferowany • 21.11 termin końcowy

Karta jest „kontraktem” projektu: pomaga mi zaakceptować zakres, a Wam nie tracić czasu na pracę, która nie prowadzi do zaliczenia.

Zasady bezpieczeństwa i etyki

DOZWOLONE

- własna aplikacja
- OWASP Juice Shop / WebGoat / DVWA
- środowisko lokalne / kontener Docker / maszyna wirtualna (VM)
- celowo podatne API
- symulacja usług chmurowych (mock)
- dane syntetyczne
- testy po uzyskaniu jednoznacznej zgody właściciela

NIEDOZWOLONE

- skanowanie publicznych usług „na próbę”
- obchodzenie cudzych zabezpieczeń
- testy na realnych kontach osób trzecich
- pozyskiwanie lub publikacja prawdziwych danych
- użycie cudzych kluczy / tokenów / sekretów
- działanie poza zaakceptowanym zakresem

W RAPORCIE

- deklaracja zakresu i zgody
- wersje narzędzi / aplikacji
- dowody bez haseł, tokenów i innych sekretów
- anonimizacja danych
- bezpieczne dane testowe (payloady) demonstracyjne
- odtwarzalność bez tworzenia materiału gotowego do nadużycia
- rekomendacje i retest

Zasada nadrzędna: testujesz tylko to, do czego masz prawo i co zostało uzgodnione jako środowisko laboratoryjne.

FORMAT ZALICZENIA

Obrona projektu — 10–12 minut

1 min

Problem

co chronimy / dlaczego

2 min

Model

architektura + ryzyko

4–5 min

Demonstracja (Demo)

podatność / zabezpieczenie / dowody

2 min

Poprawka + test ponowny

co zmieniono i jaki jest efekt

1–2 min

Wnioski

standardy + dalsze kroki

+ ok. 3 min pytań. Każdy członek zespołu odpowiada za zrozumienie projektu, nie tylko „swojej części slajdów”.

Start dziś: trzy decyzje przed wyjściem z zajęć

1
9B005D

2–3 osoby; docelowo 9 zespołów

2
2563EB

P1–P12 albo własny temat po akceptacji

3
16A34A

jaki dowód + poprawkę + test ponowny pokażecie 25.10

Cel organizacyjny: do 11.10 mam od każdego zespołu Kartę projektu v0.1.

Źródła i standardy wykorzystane do aktualizacji programu

01	**OWASP Top 10:2025**	aktualna wydana wersja Top 10; 10 kategorii ryzyk web
02	**OWASP ASVS 5.0.0**	aktualna stabilna wersja standardu wymagań weryfikacyjnych
03	**OWASP WSTG 4.2**	stabilny przewodnik testowania bezpieczeństwa aplikacji webowych
04	**OWASP API Security Top 10:2023**	specyficzne ryzyka i scenariusze dla API
05	**NIST SP 800-218 — SSDF v1.1**	ramy i praktyki bezpiecznego wytwarzania oprogramowania
06	**W3C WebAuthn Level 3**	Recommendation z 25.08.2026 — podstawa projektu passkeys